

# Exploit DVWA

## XSS e SQL Injection

Pratica S6/L2 | Epicode Cybersecurity | 12 Maggio 2026

### 1. Obiettivi dell'Esercizio

L'esercizio prevede la configurazione del laboratorio virtuale e lo sfruttamento di due classi di vulnerabilità sulla piattaforma DVWA (Damn Vulnerable Web Application): XSS Reflected e SQL Injection (non blind). L'obiettivo è dimostrare come queste vulnerabilità possano essere sfruttate in un ambiente controllato e comprenderne le implicazioni per la sicurezza.

### 2. Dettagli della Traccia

| Campo          | Dettaglio                                                       |
|----------------|-----------------------------------------------------------------|
| Corso          | Epicode - Cybersecurity                                         |
| Pratica        | S6/L2 - Exploit DVWA                                            |
| Argomento      | Sfruttamento delle vulnerabilità XSS e SQL Injection sulla DVWA |
| Piattaforma    | Damn Vulnerable Web Application (DVWA) v1.0.7                   |
| Sicurezza DVWA | LOW                                                             |
| Attaccante     | Kali Linux (macchina virtuale)                                  |
| Target         | 192.168.56.101 (DVWA)                                           |
| Data           | 12 Maggio 2026                                                  |

### 3. Configurazione del Laboratorio

Il laboratorio è composto da due macchine virtuali in rete privata host-only:

- Macchina attaccante: Kali Linux (browser Chromium per l'accesso a DVWA).
- Macchina target: DVWA accessibile all'indirizzo 192.168.56.101.
- Connettività verificata tramite il comando `ping 192.168.56.101`.
- Livello di sicurezza DVWA impostato su LOW dalla pagina Setup.

### 4. Vulnerabilità Sfruttate

#### 4.1 XSS Reflected

Il modulo XSS Reflected di DVWA accetta un parametro name via GET e lo riflette direttamente nella risposta HTML senza alcuna sanitizzazione. Questo consente l'iniezione di codice JavaScript arbitrario eseguito nel browser della vittima nel contesto del sito vulnerabile.

**Payload utilizzato**

```
/dvwa/vulnerabilities/xss_r/?name=alert('Mamt a pecr, XSS Attack!')
```

**Risultato**

Il payload è stato iniettato nel campo name e inviato tramite URL. Il browser ha eseguito il codice JavaScript, mostrando un dialog di alert con il messaggio 'Mamt a pecr, XSS Attack!' proveniente dal dominio 192.168.56.101. Questo dimostra che qualunque script può essere eseguito nel contesto della sessione dell'utente.

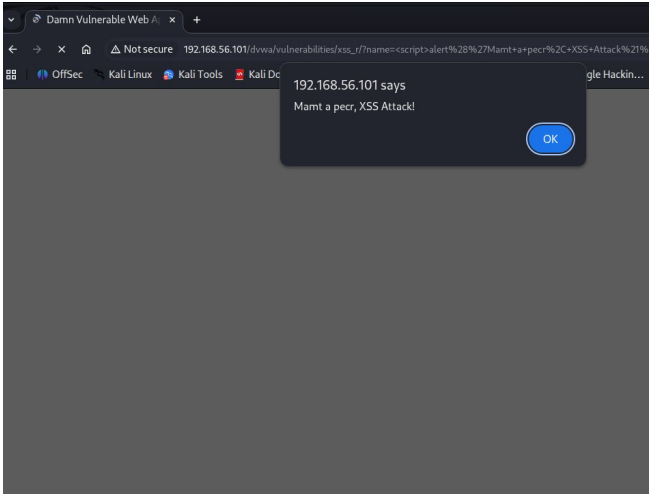


Figura 1: Alert JavaScript eseguito con successo tramite XSS Reflected.

**4.2 SQL Injection (UNION-based)**

Il modulo SQL Injection di DVWA accetta un parametro id che viene inserito direttamente nella query SQL senza sanitizzazione. Sfruttando un attacco UNION-based, è possibile aggiungere una seconda SELECT alla query originale per estrarre dati da tabelle arbitrarie del database.

**Payload utilizzato**

```
/dvwa/vulnerabilities/sqli/?id=1' UNION SELECT user, password FROM users#&Submit;=Submit#
```

**Risultato**

La query iniettata ha forzato il database a restituire anche le colonne user e password dalla tabella users. Sono stati esfiltrati i seguenti dati (password in formato hash MD5):

| Username | Password Hash (MD5)              |
|----------|----------------------------------|
| admin    | 5f4dcc3b5aa765d61d8327deb882cf99 |
| gordonb  | e99a18c428cb38d5f260853678922e03 |
| 1337     | 8d3533d75ae2c3966d7e0d4fcc69216b |
| pablo    | 0d107d09f5bbe40cade3de5c71e9e9b7 |

|        |                                  |
|--------|----------------------------------|
| smithy | 5f4dcc3b5aa765d61d8327deb882cf99 |
|--------|----------------------------------|

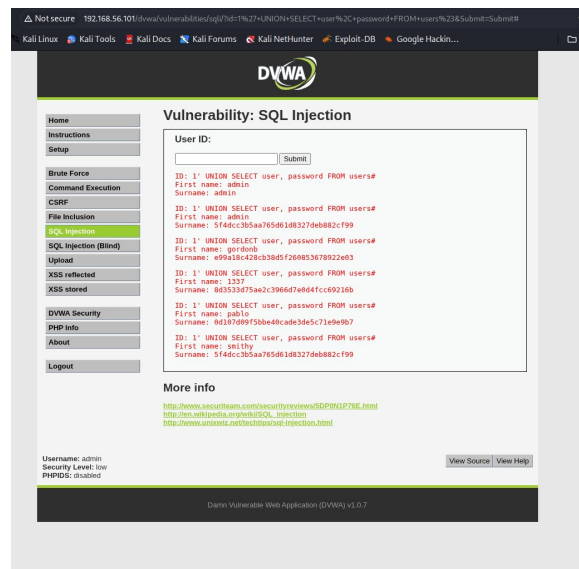


Figura 2: Credenziali estratte tramite SQL Injection UNION-based.

## 5. Considerazioni sulla Sicurezza

| Vulnerabilità | Severità | Contromisure                                                                                                                                                     |
|---------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| XSS Reflected | Alta     | Effettuare l'encoding dell'output (htmlspecialchars in PHP), validare e sanitizzare tutti gli input utente, adottare una Content Security Policy (CSP) rigorosa. |
| SQL Injection | Critica  | Utilizzare prepared statements e query parametrizzate, applicare il principio del minimo privilegio al database, non esporre messaggi di errore SQL all'utente.  |

## 6. Conclusioni

Entrambe le vulnerabilità sono state sfruttate con successo in ambiente controllato. L'esercizio dimostra concretamente come input non validati possano portare all'esecuzione di codice arbitrario (XSS) o all'esfiltrazione completa di dati sensibili (SQL Injection). Le tecniche applicate sono quelle trattate nella lezione teorica S6/L2 del corso Epicode Cybersecurity.